SIMATS ENGINEERING

CRYPTOGRAPHY AND NETWORK SECURITY (CSA51)
ASSESSMENT TOOL 2 — MODEL ANSWERS

CO2: Analyze public-key cryptosystem strategies using RSA and key exchange for encryption to strengthen information security.

Note: These are structured model answers for study and reference. Review them and write the final submission in your own words according to your course guidelines.

1. Secure Data Transmission using Block Cipher

A. Why does this issue occur?

ECB (Electronic Codebook) mode encrypts every plaintext block independently using the same key. Therefore, identical plaintext blocks produce identical ciphertext blocks. Repeated financial data can create visible patterns in the ciphertext, revealing information about the structure of the original data even though the contents are encrypted.

B. Suggest a more secure mode and justify your choice.

CBC (Cipher Block Chaining) is a better choice than ECB for this scenario because each plaintext block is combined with the previous ciphertext block before encryption. The first block uses a random, unpredictable initialization vector (IV). As a result, identical plaintext blocks are unlikely to produce identical ciphertext blocks. The IV must be unique/unpredictable as required by the mode, and integrity protection should also be provided. In modern systems, authenticated encryption such as AES-GCM is generally preferred because it provides confidentiality and integrity together.

2. Choosing an Encryption Algorithm for Banking System

A. Identify the most suitable algorithm.

Among the three options listed, Blowfish is generally the most suitable choice for this scenario if the system must choose only from DES, 3-DES, and Blowfish. However, for a real modern banking application, AES or another approved modern authenticated-encryption scheme should be selected instead.

B. Justify the choice based on security strength and efficiency.

DES has an effective key length of only 56 bits, making it vulnerable to brute-force attacks. 3-DES applies DES three times and is stronger than DES, but it is slow and is being phased out for new encryption systems. Blowfish supports variable key lengths up to 448 bits and is generally faster than 3-DES in software, so it offers a better balance among these three options. Nevertheless, Blowfish has a 64-bit block size, which can be a limitation for large amounts of data, and it is not the preferred modern standard for new banking systems.

3. Key Exchange in an Unsecured Network

A. Explain how the key exchange works.

Diffie–Hellman allows two users to establish a shared secret over a public network without sending the secret itself. They agree publicly on parameters, usually a large prime number p and a generator g. User A chooses a private value a and sends A = g^a mod p. User B chooses a private value b and sends B = g^b mod p. A calculates K = B^a mod p, while B calculates K = A^b mod p. Both obtain the same shared secret K, which can be used to derive a symmetric encryption key.

B. Identify a threat and suggest a solution.

A major threat is a man-in-the-middle (MITM) attack. An attacker may intercept the public values and establish separate shared secrets with each user, allowing the attacker to relay or alter messages. Basic Diffie–Hellman does not authenticate the users. To mitigate this, authenticate the exchange using digital certificates and digital signatures, or use a trusted authenticated protocol such as TLS with certificate validation. Use strong, modern Diffie–Hellman parameters and an approved key-derivation function.

4. Public Key Cryptography for Email Security

A. Describe RSA encryption and decryption.

Each user generates an RSA key pair: a public key and a private key. To send a confidential email, the sender encrypts a randomly generated symmetric session key using the recipient's authenticated RSA public key. The recipient uses their private key to recover the session key, then decrypts the email with the symmetric algorithm. This hybrid approach is more efficient than encrypting the entire email directly with RSA. In practice, secure RSA encryption should use a suitable padding scheme such as RSA-OAEP.

B. Explain the role of key distribution and management.

The sender must obtain the correct recipient public key and verify that it belongs to that recipient, commonly through a trusted certificate authority and digital certificate. Private keys must be kept secret, protected with access controls and secure storage, backed up or recovered only under an appropriate policy, and replaced or revoked if compromised. Certificates must be checked for validity and revocation. Digital signatures can also be used to verify the sender's identity and detect changes to the email; signing and encryption serve different purposes.

5. Cryptography for IoT Devices

A. Analyze the constraints of IoT devices.

Many IoT devices have limited processing power, memory, battery life, and bandwidth. They may also communicate over low-speed or unreliable networks. A suitable cryptographic method should provide strong security while keeping computation, message size, energy use, and implementation complexity low.

B. Recommend an approach and justify it.

ECC (Elliptic Curve Cryptography) is generally a better fit than traditional RSA for constrained IoT devices. ECC can provide comparable security with much smaller keys, which reduces storage, communication overhead, and often computation and energy costs. ECC is commonly used for key exchange and digital signatures; symmetric authenticated encryption can then protect device data. Implementations should use well-reviewed, standard curves and protocols, secure key storage, and proper authentication. The exact choice should be based on the device's hardware and supported standards.